

Appendix B: Glossary

Access point: Methods of connection that include a user's home network, cellular network, NFC, Bluetooth, or public Wi-Fi connections, such as those provided by a municipality or business.

Application security: The use of software, hardware, and procedural methods to protect applications from external threats.

Application store: A type of digital distribution platform for computer software, often in a mobile context.

Biometric: The measuring and analysis of such physical attributes as facial features and voice or retinal scans. This technology can be used to define an individual's unique identity, often for security purposes.

CHIPS: A private-sector U.S.-dollar funds transfer system, clearing and settling cross-border and domestic payments.

Code analysis: Use of tools to analyze source code and/or compiled version of code in order to help find security flaws.

Cross-site scripting: A type of computer security vulnerability typically found in web applications that enables attackers to inject client-side scripts into web pages viewed by other users. A cross-site scripting (XSS) vulnerability may be used by attackers to bypass access controls such as the same-origin policy. Anti-XSS features help protect applications from cross-site scripting attacks.

Data security: The process of safeguarding important information from unauthorized access, corruption, or loss.

Data transmission security: The transfer of confidential or proprietary information over a secure channel.

Debit card: A payment card issued as either a PIN-based debit (ATM) card or as a signature-based debit card from one of the bankcard associations. A payment card issued to a person for purchasing goods and services through an electronic transfer of funds from a demand deposit account rather than using cash, checks, or drafts at the point-of-sale.

Debit entry: An entry to the record of an account to represent the transfer or removal of funds from the account.

Deferred net settlement: See "National Settlement Service".

Depository: An institution that holds funds or marketable securities for safekeeping.

Depositories may be privately or publicly operated and allow securities transfers through book-entry and offer funds accounts permitting funds transfers as a means of payment.

Depository bank (Check 21): Also known as Bank of First Deposit (BOFD). The first bank to which a check is transferred even though it is also the paying bank or the payee. A check deposited in an account is deemed to be transferred to the financial institution holding the account into which the check is deposited, even though the check is physically received and endorsed first by another financial institution.

Device fingerprinting: Information collected about a remote computing device for the purpose of identification.

Direct debit: Electronic transfer, usually through ACH, out of an individual's checking (or savings) account to pay bills, such as mortgage payments, insurance premiums, and utility payments. Also referred to as "direct payment."

Direct deposit: Electronic deposits or credit, usually through ACH, to an individual's deposit account. Common uses of direct deposit include payroll payments, Social Security benefits, and income from investments such as CDs, annuities, and mutual funds.

Direct presentment: Depository banks can present checks directly to the paying institution. The paying institution may be the depository bank (no settlement is needed), or, if not, may settle on the books of the Federal Reserve, using the Federal Reserve's national settlement service.

Electronic Benefits Transfer (EBT): A type of EFT system involving the transfer of public entitlement payments, such as welfare or food stamps, through direct deposit or point-of-sale technology (see POS). The recipient can be given an identification card, similar to a benefit card, and a PIN allowing access to the benefits through an electronic network.

Electronic bill presentment and payment (EBPP): An electronic alternative to traditional bill payment, allowing a merchant or utility to present its customers with an electronic bill and the payer to pay the bill electronically. EBPP systems usually fall within two models: direct and consolidation-aggregation. In the direct model, the merchant or utility generates an electronic version of the consumer's billing information, and notifies the consumer of a pending bill, generally via e-mail. The consumer can initiate payment of the electronically presented bill using a variety of payment mechanisms, typically a credit card. In the consolidation-aggregation model, the consumer's bills are consolidated by a consolidator acting on behalf of merchants and utilities (or aggregated on behalf of the consumer), combining data from multiple bills and presenting a single source for the consumer to initiate payment. Some consolidators present bills at their own web sites, typically most support the aggregation of bills by consumer service providers such as Internet portals, financial institutions, and brokerage web sites.

Electronic check conversion: The process by which a check is used as a source of information for the check number, the customer's account number, and the number that identifies the financial institution. The information is used to make a one-time electronic payment from the customer's account -- an electronic fund transfer. The check itself is not the method of payment.

Electronic check presentment (ECP): Check truncation methodology in which the paper check's MICR line information is captured and stored electronically for presentment. The physical checks may or may not be presented after the electronic files are delivered, depending on the type of ECP service that is used.

Electronic commerce (E-Commerce): A broad term encompassing the remote procurement and payment by businesses or consumers of goods and services through electronic systems such as the Internet.

Electronic data capture (EDC): Process used for capturing and transferring the encoded information on the magnetic strip from a bankcard or debit card at the point-of-sale to the processor's database.

Electronic funds transfer (EFT): A generic term describing any transfer of funds between parties or depository institutions through electronic data systems.

Electronically-created payment orders: These are payment orders received by merchants from consumers, typically by telephone or the Internet. These payment orders are processed through the check processing system although they were not initiated as paper checks. These payment orders are not subject to check law and are not warranted by the Federal Reserve Banks.

Encryption: A data security technique used to protect information from unauthorized inspection or alteration. Information is encoded so that data appears as a meaningless string of letters and symbols during delivery or transmission. Upon receipt, the information is decoded using an encryption key.

Expedited Funds Availability Act (EFAA): See "Regulation CC".

Federal Reserve Banks: The Federal Reserve Banks provide a variety of financial services including retail and wholesale payments. The Federal Reserve Bank operates a nationwide system for clearing and settling checks drawn on depository institutions located in all regions of the United States.

Fedwire®: The Federal Reserve Bank's nationwide real time gross settlement electronic funds and securities transfer network. Fedwire® is a credit transfer system. Each funds transfer is settled individually against an institution's reserve or clearing account on the books of the Federal Reserve. The transaction is considered an irrevocable payment as it is processed.

Finality: Irrevocable and unconditional transfer of payment during settlement.

Financial EDI (FEDI): Financial electronic data interchange. An instrument for settling invoices by initiating payments, processing remittance data and automating reconciliation, through the exchange of electronic messages.

Firewall: A hardware or software link in a network that relays only data packets clearly intended and authorized to reach the other side.

Firmware: A software program or set of instructions programmed on a hardware device.

Float: Funds held by an institution during the check-clearing process before being made available to a depositor. Interest may be earned on these funds.

Geolocation: The identification of the real-world geographic location of an object, such as a radar source, mobile phone or Internet-connected computer terminal.

Image archive (Check 21): Database for storage and easy retrieval of check images.

Image capture (Check 21): The process of digitizing both sides of physical items and their assorted MICR information as they are processed at the Federal Reserve Bank. Also includes storage of the images for up to 60 days.

Image exchange (Check 21): Exchange of some or all of the digitized images of a check.

Indemnifying bank (Check 21): A financial institution that transfers, presents, or returns a substitute check or a paper or electronic representation of a substitute check for which it receives consideration. The financial institution shall indemnify the recipient and any subsequent recipient (including a collecting or returning financial institution, the depository financial institution, the drawer, the drawee, the payee, the depositor, and any endorser) for any loss incurred by any recipient of a substitute check if that loss occurred due to the receipt of a substitute check instead of the original.

Interbank checks: Checks that are not “on-us.” They are cleared and settled either by direct presentment, a clearinghouse association, a correspondent bank, or a Federal Reserve Bank.

Interchange: Exchange of transactions between financial institutions participating in a bank card network, based on a common set of rules. Card interchange allows a financial institution’s customers to use a bank credit card at any card honoring merchant and to gain access to multiple ATM systems from a single ATM.

Interchange (fees): Fees paid by one financial institution to another to cover handling costs and credit risk in a financial institution card transaction. Interchange fees generally flow toward the institution funding the transaction and assuming the risk. In a credit card transaction, the interchange fee is paid by the merchant acquirer accepting the merchant’s sales draft to the card-issuing institution, which, in turn, passes the fee to its merchants. In EFT/POS transactions, interchange flows in the opposite direction: the card-issuing institution (or customer) pays the fee to the terminal-owning institution. When a transaction is an off-line debit sale, the card-issuing institution collects an interchange fee from the merchant, rather than from the customer, unlike in an EFT/POS transaction, where the customer pays the interchange fee. Interchange revenue is derived from fees set by the card associations. Depending on the card association, fees can range from 1% to 3% of the value of the transaction. Interchange revenue is recognized as a card issuer’s second largest revenue line item.

Internet: A worldwide network of computer networks, governed by standards and protocols

developed by the Internet Engineering Task Force (IETF).

Jailbreaking: A method of removing the manufacturer's device controls or core operating system controls to provide a user with additional access to and control over the device's operating and file systems, including the ability to circumvent security controls.

Large value funds transfer system: A wholesale payment system used primarily by financial institutions in which large values of funds are transferred between parties. Fedwire® and CHIPS are the two large-value transfer systems in the United States.

Lockbox: Deposit mechanism used by commercial firms and businesses to facilitate their deposit transaction volume. Typically, commercial firms and businesses direct customers to send payments directly to a financial institution address or post office box controlled by the institution. Financial institution personnel record payments received and prepare deposit slips, and subsequent processing proceeds as with other deposit taking activities.

Merchant acquirer: Bankcard association members that initiate and maintain contractual agreements with merchants for the purpose of accepting and processing bankcard transactions.

Merchant processing: Activity for the acceptance and settlement of bankcard products and transactions from merchants through the payment system.

Mobile application: Downloadable software applications developed specifically for use on mobile devices. Mobile financial applications are developed by or for financial institutions to allow customers to perform account inquiries, retrieve information, or initiate financial transactions.

Mobile device: A portable computing and communications device with information-storage capability.

Mobile device security: Controls to protect unauthorized access to or activities through portable computing and communications devices.

Mobile financial services: The products and services that a financial institution provides to its customers through mobile devices.

Mobile P2P: Payments initiated on a mobile device using the recipient's mobile phone number, e-mail address, or other identifier.

Mobile payment: A transfer of value via a mobile device.

Mobile wallet: A front-end application that stores payment card information on the mobile device and allows payments to be made using a mobile device. The mobile wallet utilizes traditional retail payment channels such as ACH, EFT, and debit/credit card networks to process the payments.

Mobile-enabled Web sites: A Web site is designed to detect the type of device the customer is using (e.g., mobile device or desktop computer) and displays Web pages in the best format

for that device.

Multilateral netting settlement system: Multilateral netting is an arrangement among three or more parties to net their obligations. In these settlement systems transfers are irrevocable but are only final after the completion of end-of-day-settlement.

NACHA: The Electronic Payments Association (NACHA) - The national association that establishes the rules and procedures governing the exchange of ACH payments.

National Settlement Service (NSS): Also referred to as Deferred Net Settlement. The Federal Reserve Banks' multilateral settlement service. NSS is offered to depository institutions that settle for participants in clearinghouses, financial exchanges, and other clearing and settlement groups. Settlement agents acting on behalf of those depository institutions electronically submit settlement files to the Federal Reserve Banks. Files are processed on receipt, and entries are automatically posted to the depository institutions' Reserve Bank accounts. Entries are final when posted.

Near field communication (NFC): A wireless protocol that allows for exchange of payment credentials stored on the mobile device and other data at close range.

Net debit cap: The maximum dollar amount of uncollateralized daylight overdrafts that an institution is authorized to incur in its Federal Reserve account. The net debit cap is generally equal to an institution's capital times the cap multiple for its cap category.

Office of Foreign Asset Control (OFAC): The Office of Foreign Assets Control, United States Department of the Treasury, administers and enforces economic sanctions programs primarily against countries and groups of individuals such as terrorists and narcotics traffickers. The sanctions can be either comprehensive or selective, using the blocking of assets and trade restrictions to accomplish foreign policy and national security goals.

One-time password: A password that is valid for only one login session or transaction on a computer system or other digital device.

On-us checks: Checks that are deposited into the same institution on which they are drawn.

Originating depository financial institution (ODFI): A participating financial institution that originates entries at the request of and by agreement with its originators in accordance with the provisions of the NACHA rules.

OWASP: An online community dedicated to Web application security.

Paying bank: A paying bank is the institution where a check is payable and to which it is sent for payment.

Payment: A transfer of value.

Payment system: The mechanism, the rules, institutions, people, markets, and agreements that make the exchange of payments possible.

Payments System Risk Policy (PSR): The Federal Reserve's Payments System Risk (PSR) policy addressing the risks that payment systems present to the Federal Reserve Banks, the banking system, and to other sectors of the economy.

Payroll card account: A bank account that is established directly or indirectly by an employer on behalf of an employee to which an electronic funds transfers the employee's wages or compensation on a recurring basis. The payroll card, often branded by one of the credit/debit card associations, provides the employee access to the funds.

Person-to-person (P2P) payment: Online payments using electronic mail messages to invoke a transfer of value between the parties over existing proprietary networks as on-us transactions.

Point-of-sale (POS) network: A network of institutions, debit cardholders, and merchants that permit consumers to make direct payment electronically at the place of purchase. The funds are withdrawn from the account of the cardholder.

Presentment fee: A fee that an institution receiving a check may impose on the institution that presents the check for payment. No presentment fee may be charged for checks presented by 8 a.m. local time.

Private label card: See "Store Card".

QR code: A type of two-dimensional bar code or machine-readable optical label that contains information about the item to which it is attached.

Real time gross settlement (RTGS) System: A type of payments system operating in real time rather than batch processing mode. It provides immediate finality of transactions. Gross settlement refers to the settlement of each transfer individually rather than netting. Fedwire® is an example of a real time gross settlement system.

Receiver: An individual, corporation, or other entity that has authorized a company or an originator to initiate a credit or debit entry to a transaction account belonging to the receiver held at its RDFI.

Receiving depository financial institution (RDFI): Any financial institution qualified to receive debits or credits through its ACH operator in accordance with the ACH rules.

Reconverting bank (Check 21): The financial institution that creates a substitute check. With respect to a substitute check that was created by a person that is not a financial institution, the reconverting bank is the first financial institution that transfers, presents, or returns that substitute check or, in lieu thereof, the first paper or electronic representation of that substitute check. The reconverting bank warrants that (1) the substitute check is the legal equivalent of the original check; and (2) the original check cannot be presented again in any form so the customer pays the check only once.

Regulation CC: A regulation (12 CFR 229) promulgated by the Board of Governors of the Federal Reserve System regarding the availability of funds and the collection of checks. The regulation governs the availability of funds deposited in checking accounts and the collection

and return of checks.

Regulation E: A regulation (12 CFR 205) promulgated by the Board of Governors of the Federal Reserve System to ensure consumers a minimum level of protection in disputes arising from electronic fund transfers.

Regulation Z: Regulation Z, the Truth in Lending Act (TILA) (12 CFR 226) promulgated by the Board of Governors of the Federal Reserve System. The regulation prescribes uniform methods for computing the cost of credit, disclosing credit terms, and resolving errors on certain types of credit accounts.

Remittance cards: Payment cards that are typically used to facilitate cross-border movement of funds by individuals and for person-to-person transactions.

Remote deposit capture (RDC): A service that enables users at remote locations to scan digital images of checks and transmit the captured data to a financial institution or a merchant that is a customer of a financial institution.

Remotely created check (RCC): A check that is drawn on a customer account at a financial institution, is created by the payee, and does not bear a signature in the format agreed to by the paying financial institution and customer. RCCs are also known as “demand drafts,” “telechecks,” “preauthorized drafts,” “paper drafts,” or “digital checks.”

Reserve account: A non-interest-earning balance account institutions maintain with the Federal Reserve Bank or with a correspondent bank to satisfy the Federal Reserve’s reserve requirements. Reserve account balances play a central role in the exchange of funds between depository institutions.

Reserve requirements: The percentage of deposits that a depository institution may not lend out or invest and must hold either as vault cash or on deposit at a Federal Reserve Bank. Reserve requirements affect the potential of the banking system to create transaction deposits.

Retail payments: Payments, typically small, made in the goods and services market.

Return (ACH): Any ACH entry that has been returned to the ODFI by the RDFI or by the ACH operator because it cannot be processed. The reason for each return is included with the return in the form of a “return reason code.” (See the NACHA “Operating Rules and Guidelines” for a complete reason code listing.)

Rogue code: In programming, rogue code is another term for code that constitutes a virus.

Root user: The conventional name of the user who has all rights or permissions to all files and programs. Having such rights or permissions allow the root user to do many things an ordinary user cannot.

Routing number: Also referred to as the ABA number. A nine-digit number (eight digits and a check digit) that identifies a specific financial institution.

Secure coding techniques: The process of developing code (e.g., Web application) with security built in during the development process using technical controls to mitigate the occurrence of software vulnerabilities.

Settlement: The final step in the transfer of ownership involving the physical exchange of securities or payment. In a banking transaction, settlement is the process of recording the debit and credit positions of the parties involved in a transfer of funds. In a financial instrument transaction, settlement includes both the transfer of securities by the seller and the payment by the buyer. Settlements can be “gross” or “net.” Gross settlement means each transaction is settled individually. Net settlement means parties exchanging payments will offset mutual obligations to deliver identical items (e.g., dollars or EUROS), at a specified time, after which only one net amount of each item is exchanged.

Settlement date (ACH): The date on which an exchange of funds with respect to an entry is reflected on the books of the Federal Reserve Bank.

Short message service: A text messaging service component of phone, Web, or mobile communication systems. SMS uses standardized communications protocols to allow devices to exchange short text messages. Also known as text messaging.

Single-Entry (ACH): A one-time transfer of funds initiated by an originator in accordance with the receiver’s authorization for a single ACH credit or debit to the receiver’s consumer account.

Standard Entry Class (SEC) code: Three-character code in an ACH company/batch header record used to identify the payment type within an ACH batch.

Store card: A credit card issued by a financial institution for a specific merchant or vendor that does not carry a bankcard association logo. Store cards can only be used at the merchant or vendor whose name appears on the front of the card.

Stored-value card: A card-based payment system that assigns a value to the card. The card’s value can be stored on the card itself (i.e., on the magnetic stripe or in a computer chip) or in a network database. As the card is used for transactions, the transaction amounts are subtracted from the card’s balance. As the balance approaches zero, some cards can be “reloaded” through various methods and others are designed to be discarded. These cards are often used in closed systems for specific types of purchases.

Substitute check (Check 21): Also known as the Image Replacement Document (IRD). A paper reproduction of an original check that (1) contains an image of the front and back of the original check; (2) bears a MICR line that, except as provided under ANS X9.100-140, contains all the information appearing on the MICR line of the original check when it was issued and any additional information that was encoded on the original check’s MICR line before an image of the original check was captured; (3) conforms in paper stock, dimension, and otherwise with ANS X9.100-140; and (4) is suitable for automated processing in the same manner as the original check. The Federal Reserve Board of Governors can by rule or order determine different standards.

Third-party sender: A special subset of a technology service provider that is authorized to

transmit ACH files on behalf of an originator. Typically, the ODFI must rely upon warranties by the third- party sender regarding the originators' identity and credit worthiness, which places additional risks on the ODFI.

Third-party service provider (TPSP)(For ACH): A third party, other than the ODFI or RDFI, that performs any function on behalf of the ODFI or the RDFI related to ACH processing. These functions would include the creation and sending of ACH files or acting as a sending or receiving point on behalf of a participating depository financial institution.

Threat modeling: A structured approach that enables an institution to aggregate and quantify potential threats. In the context of application development, threat modeling can be used to capture, organize, and analyze all of the threat information of an application and its environment that affects application security. It is used to enable informed decision-making about application security and helps to produce and rank a list of security improvements.

Token: A small device with an embedded computer chip that can be used to store and transmit electronic information. A soft token is a software-based token.

Tokenization: The process of substituting a sensitive data element with a surrogate value, referred to as a token.

Truncating bank (Check 21): The financial institution that truncates the original check. If a person other than a financial institution truncates the original check, the truncating bank is the first financial institution that transfers, presents, or returns, in lieu of such original check, a substitute check or, by agreement with the recipient, information relating to the original check (including data taken from the MICR line of the original check or an electronic image of the original check), whether with or without the subsequent delivery of the original check.

Trusted platform module: An international standard for a secure crypto processor that is a dedicated microprocessor designed to secure hardware by integrating cryptographic keys into devices.

USA Patriot Act: The USA PATRIOT Act (Uniting and Strengthening America by Providing Appropriate Tools Required to Intercept and Obstruct Terrorism Act of 2001 (Public Law Pub.L. 107-56), commonly known as the "Patriot Act", was enacted by Congress to deter and punish terrorist acts in the United States and around the world by enhancing the law enforcement investigatory tools of both domestic law enforcement and foreign intelligence agencies.

Virtual payment card: A controlled way of making payments by generating a unique credit card number to settle a specific transaction typically online. Also referred to as single-use credit cards.

WEB SEC code: An ACH debit entry initiated by an originator resulting from the receiver's authorization through the Internet to make a transfer of funds from a consumer account of the receiver.

White-hat hacking: The specialization of penetration testing and other testing methodologies to review the security of an institution's information systems by determining